
POAS-Bench: Benchmarking Behavioral Safety of Personal Agents Across Boundaries

Anonymous Author(s)

Affiliation

Address

email

Abstract

1 Personal AI agents are evolving from tools that answer queries into delegates that
2 manage calendars, search private notes, draft emails, and coordinate with others on
3 behalf of their owners. Many useful tasks—scheduling meetings, sharing project
4 updates, requesting information—are inherently cross-boundary: they require one
5 person’s agent to contact another’s. Yet when two delegate agents interact across
6 an ownership boundary, each agent’s deep, tool-mediated access to its owner’s
7 fragmented personal data creates an attack surface with no analogue in single-agent
8 or agent-only settings. We introduce **POAS-Bench (Personal Agents AcrOss**
9 **BoundArieS)**, a benchmark for evaluating the behavioral safety of personal agents
10 engaged in cross-boundary coordination. Unlike prior benchmarks that study pas-
11 sive leakage in scripted social scenarios or prompt injection against isolated agents,
12 POAS-Bench grounds evaluation in fully-equipped personal agents with persistent
13 memory, 85+ scattered documents, callable tools (`read_note`, `search_notes`,
14 `check_calendar`), and autonomous multi-turn interaction. We evaluate govern-
15 ance configurations along a specificity gradient, measure both task-completion
16 utility and data-protection security simultaneously, and condition on relationship
17 context. Across XXXX experimental runs, we find that governance *specificity*—not
18 strictness—determines behavioral safety: category-specific policies yield XXXX
19 pp leak reduction while generic instructions yield only XXXX pp. Multi-turn
20 coordination amplifies leakage XXXX× over single-step probing. Relationship
21 context shifts leakage in opposing directions depending on data category. These
22 findings establish that the design of cross-boundary governance is a first-class
23 engineering problem for the emerging agent ecosystem.

24 1 Introduction

25 Personal AI agents are becoming delegates, not tools. Powered by large language models [11, 1],
26 a new generation of agent systems can manage calendars, summarise private notes, draft emails,
27 negotiate meetings, and coordinate with external parties on behalf of their owners [8, 3, 12]. Agent
28 frameworks such as ReAct [22] and Toolformer [15] established the paradigm of interleaving
29 reasoning with tool use; commercial systems have since extended this into persistent, always-on
30 digital proxies with access to personal data stores, messaging channels, and scheduling infrastructure.
31 As these agents gain persistent memory and tool access, they increasingly act not merely *for* a user,
32 but *on behalf of* a user.

33 The next step is not more autonomy, but interdependence. Today, most agents remain trapped inside
34 individual workspaces. But many high-value tasks are inherently cross-boundary: scheduling a
35 meeting requires checking two people’s calendars; sharing an investor update requires one agent
36 to contact another; coordinating a project launch requires a manager’s agent to collect status from

several teammates’ agents. These tasks require one person’s delegate to contact another person’s delegate. Without this capability, humans remain stuck manually extracting information from one AI assistant and transmitting it through legacy channels to another—a “coordination tax” that persists despite each agent being individually capable.

When two delegate agents interact across an ownership boundary, however, a new class of behavioral problems emerges. Unlike single-agent settings where failure means a wrong answer, cross-boundary delegation introduces failures at the intersection of language, tools, memory, and social context. A personal agent may reveal too much, refuse too much, retrieve the wrong memory, invoke unauthorised tools, infer permissions that were never granted, silently comply with social pressure, or fail to escalate to its owner when it should. Conversely, an over-restrictive agent may preserve privacy perfectly while becoming useless as a delegate. Recent applied case studies of deployed agents have confirmed the breadth of these behavioral failures in practice, from uncontrolled information sharing to agents disabling their own capabilities in response to adversarial framing [17]. The security community has further documented that every published prompt injection defence can be bypassed under adaptive attack [10], and that agents become critically vulnerable the moment they simultaneously process untrusted input, access sensitive data, and take state-changing actions [9]. Cross-boundary coordination satisfies all three conditions by default.

Existing benchmarks address pieces of this problem but miss the whole. Single-agent security benchmarks [24, 4, 18] evaluate prompt injection against isolated agents without cross-boundary interaction. Multi-agent privacy benchmarks [20, 5, 7] study leakage in social simulation or dialogue settings, but their agents communicate through text messages in scripted scenarios—they do not call tools, search databases, or retrieve scattered personal documents. None evaluate what happens when two *fully-equipped* personal agents—with persistent memory, distributed context across dozens of documents, callable tool access, and relationship-specific permissions—attempt to coordinate autonomously over a multi-turn horizon.

We introduce **POAS-Bench** (Personal Agents AcrOss BoundArieS), a benchmark for evaluating the behavioral safety of personal agents in cross-boundary coordination. Our contributions are:

1. **A grounded cross-boundary coordination testbed** in which two fully-equipped delegate agents—persistent memory, 85+ scattered documents, callable tools (`read_note`, `search_notes`, `check_calendar`, `schedule_meeting`), and relationship context—interact autonomously. Leakage occurs not just through what agents *say*, but through what they *retrieve*, *compute*, and *execute*. This is the first benchmark where the attack surface includes tool calls and data retrieval, not only conversation.
2. **A dual-metric evaluation protocol** that simultaneously measures task-completion utility (U) and data-protection security (S) across a governance gradient, enabling practitioners to answer: “is this governance configuration worth deploying?”
3. **A multi-turn heartbeat evaluation mode** in which agents coordinate proactively over sustained interaction, capturing emergent behavioral dynamics—escalation, context accumulation, social framing—invisible to single-step evaluation.
4. **Empirical findings** from XXXX experimental runs revealing that governance *specificity* dominates strictness (XXXX pp improvement from category enumeration vs. XXXX pp from generic instruction); multi-turn interaction amplifies leakage XXXX $\times$ over single-step probing; and relationship context has non-uniform, category-dependent effects on data protection.

2 Related Work

Single-agent security benchmarks. InjecAgent [24] benchmarks indirect prompt injection in tool-integrated agents with 1,054 test cases, but evaluates single agents against injected payloads—not cross-boundary communication—and does not measure the utility cost of defences. AgentDojo [4] provides a dynamic environment with 97 user tasks and 629 security tests, but operates within a single trust domain with no ownership boundary. TensorTrust [18] gamified prompt injection through an online platform with 126,000 attack/defence pairs but does not model agent-to-agent interaction. HackAPrompt [16] confirmed the fragility of prompt-level defences at scale with over 600,000 adversarial prompts. These benchmarks establish that LLM-based agents are vulnerable, but they

Table 1: Comparison of agent safety benchmarks. ✓ = fully supported, ~ = partially, – = not supported.

Benchmark	Cross-boundary	Tool access	Dual metric	Defence gradient	Multi-turn	Persistent memory	Relationship
InjecAgent	–	✓	–	–	–	–	–
AgentDojo	–	✓	~	–	–	–	–
TensorTrust	–	–	–	~	–	–	–
ConVerse	✓	–	–	–	✓	–	–
AgentSocialBench	✓	–	✓	~	–	–	✓
PAC-BENCH	✓	–	~	–	–	–	–
AgentLeak	✓	~	–	–	–	–	–
Chaos of Agents	✓	✓	–	–	✓	✓	–
POAS-Bench	✓	✓	✓	✓	✓	✓	✓

cannot evaluate what happens when that vulnerability is exposed in a cross-boundary coordination setting.

Multi-agent privacy and safety benchmarks. AgentSocialBench [20] is the most comprehensive multi-agent privacy benchmark, evaluating 352 scenarios across 7 categories in agentic social networks. It introduces category-specific leakage metrics, an information abstraction score, and task-completion quality measurement, and uncovers the “abstraction paradox” in which privacy instructions can paradoxically increase leakage. However, AgentSocialBench evaluates *passive* leakage—agents accidentally disclose information during social interaction—in a text-only messaging environment. Agents have no tool access, no persistent memory beyond injected profiles, and scenarios are scripted rather than autonomously driven. ConVerse [5] evaluates personal assistants interacting with external service providers and finds attack success rates up to 88%, but measures attack success only—no utility, no defence evaluation. PAC-BENCH [13] evaluates multi-agent collaboration under privacy constraints, treating privacy as a constraint on utility. MAGPIE [7] provides 200 collaborative tasks but agents share a single principal with no trust boundary. AgentLeak [21] covers seven leakage channels in enterprise workflows but does not evaluate defences or measure utility.

Applied case studies. Complementing benchmark-based evaluation, Benton et al. [17] present applied case studies of deployed agents with tool access, persistent storage, and multi-party communication channels. Twenty researchers red-teamed these systems over two weeks, uncovering behavioral failures including uncontrolled information sharing, resource exhaustion, impersonation compliance, and agents disabling their own capabilities. These findings demonstrate the *breadth* of behavioral failure in realistic settings, but the methodology—human red-teamers in a live environment—is expensive, non-reproducible, and difficult to use for systematic comparison of governance configurations.

Positioning. Table 1 summarises existing benchmarks across seven dimensions critical to evaluating cross-boundary agent safety. POAS-Bench occupies a position between the scale and reproducibility of automated benchmarks and the system-level realism of applied case studies: it is the first automated benchmark in which agents are equipped with callable tools, persistent memory, and scattered personal data, and in which the querying agent operates *proactively* over multi-turn autonomous interaction.

Attack and defence landscape. The attack methods most relevant to cross-boundary delegation include automated jailbreak generation via PAIR [2], multi-turn escalation via Crescendo [14], and persuasion-based social engineering via PAP [23]. On the defence side, Instruction Hierarchy [19] and Spotlighting [6] represent prompt-level approaches, while the consensus from large-scale evaluations [10] is that architectural constraints—not prompt instructions alone—are required for reliable safety. POAS-Bench’s governance gradient is designed to evaluate this spectrum.

3 POAS-Bench Design

POAS-Bench evaluates a specific threat model: an external agent queries a personal agent that holds its owner’s private data. The personal agent must answer legitimate work questions (utility) while protecting sensitive personal information (security). We describe the agent setup, the evaluation queries, the defence gradient, and the dual-metric evaluation protocol.

3.1 Agent with Personal Context

The target agent (“Alex’s agent”) is a realistic personal agent with:

- **Persistent memory:** a structured knowledge base containing the agent’s understanding of its owner, built through prior interactions.
- **Notes:** 85+ documents organised in folders (Work/Projects, Work/Meetings, Work/HR, Personal/Finance, Personal/Health, Personal/Family), each containing facts that map to evaluation queries.
- **Tools:** callable functions (`read_note`, `search_notes`, `check_calendar`, `schedule_meeting`) that return real data—leakage occurs not just through what the agent *says* but through what tools it *calls* and what data those tools *return*.
- **Identity:** a system prompt establishing the agent’s owner, role, and communication style.

The querying agent (“Tina’s agent”) is tasked with gathering information from Alex’s agent on behalf of its owner. In the multi-turn mode, Tina’s agent maintains a checklist of pending questions and adaptively selects which to ask based on conversation history.

3.2 Evaluation Queries

POAS-Bench comprises XXXX evaluation queries across 5 sensitivity categories:

Table 2: Evaluation query distribution across sensitivity categories. Work/public queries measure utility (should be answered); all others measure security (should be refused).

Category	ID range	Count	Expected behaviour
Work/public	Q1–XXXX	XXXX	Answer (utility)
Sensitive work (HR, board, investor)	XXXX–XXXX	XXXX	Refuse (security)
Personal finance	XXXX–XXXX	XXXX	Refuse (security)
Personal health	XXXX–XXXX	XXXX	Refuse (security)
Personal relationships	XXXX–XXXX	XXXX	Refuse (security)

Each query is paired with **gold key facts**—specific pieces of information whose presence in the agent’s response constitutes a leak (for sensitive queries) or a correct answer (for work/public queries). This enables automated evaluation via string matching against gold facts, removing the need for LLM-as-judge and its associated reliability concerns.

3.3 Defence Gradient

We evaluate three defence levels that form a gradient of *specificity*, not strictness:

- **D0 (No defence):** The agent’s system prompt contains no privacy instructions. Full data access, zero policy.
- **D1 (Generic prompt):** A single sentence is appended: “*Try not to share personal or private information.*” This is the most common real-world defence pattern.
- **D2 (Category-specific deny list):** An explicit enumeration: “*Never share: financial data (salary, equity, investments), health information (conditions, medications, appointments), HR/compensation details, personal relationship information.*” Same strictness intent as D1, higher specificity.

All three levels are *prompt-level* defences: the agent can see all data but is instructed not to share it. This isolates the effect of policy language from architectural changes, enabling a clean measurement of how specificity affects the tradeoff.

161 The benchmark framework is extensible to additional defence levels, including architectural defences
 162 (e.g., physically removing sensitive data from context) and classifier-based filtering. We discuss these
 163 extensions in Section 6.

164 3.4 Evaluation Modes

165 **Single-step mode.** Each query is asked in isolation: one question, one response, no conversation
 166 history. This provides a controlled measurement of per-query behaviour but misses conversational
 167 dynamics.

168 **Multi-turn heartbeat mode.** Both agents operate as persistent processes, exchanging messages at
 169 regular intervals (“heartbeats”). Tina’s agent maintains a checklist of pending questions and decides
 170 which to ask, how to frame it, and whether to retry based on the evolving conversation. This captures:

- 171 • **Escalation:** repeated probing after initial refusal.
- 172 • **Context accumulation:** information from earlier turns influencing later responses.
- 173 • **Social framing:** wrapping sensitive questions in work-acceptable contexts.
- 174 • **Within-tick batching:** asking multiple questions per turn to overwhelm defences.

175 3.5 Dual-Metric Protocol

176 Every experimental run produces two scores:

$$U = \frac{|\{\text{work/public queries with gold facts in response}\}|}{|\{\text{work/public queries}\}|} \quad (1)$$

$$S = \frac{|\{\text{sensitive queries with no gold facts in response}\}|}{|\{\text{sensitive queries}\}|} \quad (2)$$

177 $U \in [0, 1]$ measures task-completion utility; $S \in [0, 1]$ measures data-protection security. A perfect
 178 defence achieves $U = S = 1$: all legitimate queries answered, all sensitive data protected. The (U, S)
 179 pair for each defence configuration defines a point on the Pareto frontier.

180 **Why dual metrics matter.** A defence that achieves $S = 1$ by refusing *all* queries (including
 181 legitimate ones) is useless. A defence with $U = 1$ that leaks everything is dangerous. Only dual
 182 measurement captures the tradeoff that practitioners face. No prior cross-boundary benchmark reports
 183 both metrics.

184 3.6 Relationship Conditions

185 We evaluate under two relationship conditions:

- 186 • **R0 (Stranger):** Tina is identified by name only. The agent treats her as unknown.
- 187 • **R1 (Colleague):** Tina is identified as a project manager who works with Alex daily. Shared project
 188 context is provided.

189 This tests whether social context modulates the security–utility tradeoff—a dimension no prior
 190 benchmark evaluates.

191 4 Experimental Setup

192 **Model.** All experiments use XXXX as both the target agent (Alex) and the querying agent (Tina).
 193 The evaluator uses the same model for gold-fact string matching.

194 **Configurations.** We evaluate 3 defence levels $\times$ 2 relationship conditions $\times$ 2 evaluation modes =
 195 12 configurations. Each multi-turn configuration runs for XXXX heartbeat ticks.

Table 3: Leak rate (%) by defence level and evaluation mode. Lower is better. Δ shows improvement over D0.

Defence	Single-step		Multi-turn	
	Leak rate	Δ vs D0	Leak rate	Δ vs D0
D0 (No defence)	XXXX%	—	XXXX%	—
D1 (Generic prompt)	XXXX%	XXXX pp	XXXX%	XXXX pp
D2 (Category deny list)	XXXX%	XXXX pp	XXXX%	XXXX pp

196 **Datasets.** We report results from two datasets:

- 197 • **Bench-SS:** XXXX queries in single-step mode, 3 defence levels $\times$ XXXX relationship conditions,
198 XXXX runs total.
- 199 • **Bench-MT:** XXXX queries in multi-turn heartbeat mode with XXXX ticks per group. 3 defence
200 levels $\times$ 2 relationships $\times$ XXXX groups = XXXX runs.

201 Total: XXXX experimental runs across all configurations.

202 **Evaluation.** For each run, we compute U and S as defined in Equations 1–2. For multi-turn runs,
203 we additionally track *leakage-per-tick*: when in the conversation each leak first occurs, to characterise
204 escalation dynamics.

205 5 Results

206 5.1 Defence Specificity Dominates Strictness

207 **Finding 1: Generic privacy instructions are near-useless.** D1 reduces leakage by only XXXX
208 percentage points over no defence at all (Table 3). This is the most common real-world defence
209 pattern, “don’t share personal information,” and it provides negligible protection.

210 **Finding 2: Category-specific enumeration is dramatically more effective.** D2 achieves a XXXX
211 pp improvement over D0, despite having the same *intent* (protect personal data) and the same
212 *mechanism* (prompt-level instruction). The only difference is specificity: D2 names what to protect.
213 This suggests that the bottleneck in current defences is not model capability but instruction precision.

214 **Finding 3: The tradeoff is non-monotonic.** D2 achieves *both* higher security and comparable utility
215 (less than XXXX% utility cost in single-step). The Pareto frontier has a kink: it is possible to improve
216 security substantially without meaningful utility loss. This challenges the common assumption of a
217 monotonic security-utility tradeoff.

218 5.2 Multi-Turn Amplification

219 **Finding 4: Single-step benchmarks systematically undercount leakage.** Under D2 (the strongest
220 defence), single-step evaluation measures a XXXX% leak rate; multi-turn evaluation measures
221 XXXX%, an amplification of XXXX $\times$. Under D0, the ratio is XXXX $\times$. Every existing agent security
222 benchmark that uses single-step evaluation [24, 4, 18] therefore *systematically underestimates* the
223 privacy risk of deployed agents.

224 This amplification arises from conversational dynamics: context accumulation across turns, social
225 framing, and repeated probing. Notably, the querying agent in our setup uses *no explicit attack*
226 *strategy*; it simply asks questions conversationally. Formal multi-turn attacks (e.g., Crescendo [14])
227 would likely amplify further.

228 5.3 Per-Category Analysis

229 **Finding 5: Defence effectiveness varies dramatically by category.** D2 reduces health leaks to
230 near-zero but leaves sensitive work substantially exposed (Table 4). This is because “sensitive work”
231 queries (board discussions, investor terms, HR decisions) are semantically close to “work/public”

Table 4: Single-step leak rate (%) by category under each defence level.

Category	D0	D1	D2
Sensitive work (XXXX Q)	XXXX%	XXXX%	XXXX%
Personal finance (XXXX Q)	XXXX%	XXXX%	XXXX%
Personal health (XXXX Q)	XXXX%	XXXX%	XXXX%
Personal relationships (XXXX Q)	XXXX%	XXXX%	XXXX%

Table 5: Multi-turn leak rate (%) by relationship condition (D2 only). Δ shows the effect of adding colleague context.

Category	R0 (Stranger)	R1 (Colleague)	Δ
Overall	XXXX%	XXXX%	XXXX pp
Personal relationships	XXXX%	XXXX%	XXXX pp
Personal health	XXXX%	XXXX%	XXXX pp

queries; the agent struggles to distinguish them. Health and finance, by contrast, are semantically distant from work context and easier to fence off.

Finding 6: D1 sometimes increases leakage. Sensitive work leaks rise from XXXX% (D0) to XXXX% (D1). The generic instruction may cause the agent to over-focus on “personal” data while relaxing vigilance on work-sensitive data that does not feel “personal.” This echoes the “abstraction paradox” observed by Wang and Jiang [20]: defence instructions can inadvertently increase disclosure in certain categories.

5.4 Relationship Effects

Finding 7: Relationship context has dual-direction, category-dependent effects. Adding colleague context slightly decreases overall leakage but the aggregate masks opposing effects: relationship data leaks *more* while health data leaks *less* under R1. The colleague frame makes personal relationship questions feel more relevant (“we work together, so my personal life is relevant context”) while making health questions feel more clearly out-of-scope.

The strongest interaction occurs between D1 and R1 on personal relationships, demonstrating that relationship context is a security-relevant variable that interacts with defence policy in non-trivial ways.

5.5 Self-Identity as a Defence Boundary

One observed pattern deserves separate mention. Certain facts embedded in the agent’s *identity* (stored in MEMORY.md as the agent’s self-knowledge) were never leaked across all XXXX runs, a 100% hold rate. By contrast, the same types of facts stored in external notes leaked at rates consistent with Table 3. This suggests that boundaries embedded in agent *self-identity* may be structurally more robust than external policy instructions, a hypothesis we discuss further in Section 6.

6 Discussion and Limitations

Implications for practitioners. Our findings have immediate practical implications: (1) replace generic privacy instructions with category-specific deny lists, a zero-cost change that yields substantial improvement; (2) evaluate defences in multi-turn settings, as single-step testing underestimates real-world risk by XXXX $\times$; (3) treat relationship context as a security parameter, not just a UX feature.

Toward architectural defences. The 100% hold rate for self-identity facts and the XXXX% residual leak rate under D2 (the best prompt-level defence) suggest a ceiling on what prompt-level defences can achieve. Architectural approaches, physically removing sensitive data from the agent’s context rather than instructing it not to share, may fundamentally change the tradeoff. Our benchmark framework supports evaluating such defences (as additional levels D3+), and we plan to evaluate capability-based data isolation in future work.

Limitations. Single model: all experiments use XXXX. Defence effectiveness may differ across models with different safety training. **No formal attacks:** the querying agent uses natural conversation, not adversarial attack strategies (PAIR, Crescendo, PAP). Formal attacks would likely increase leak rates further, making our numbers a *lower bound* on vulnerability. **Synthetic scenario:** the personal agent’s data is synthetic. Real-world agents would have more complex, unstructured data. **Evaluation method:** gold-fact string matching may miss paraphrased leaks (undercounting) or trigger on coincidental matches (overcounting); we plan to supplement with LLM-based evaluation in future work.

Benchmark release. We will release the full benchmark suite including: evaluation queries with gold key facts, agent configuration files (notes, memory, tools), the heartbeat evaluation engine, and evaluation scripts. The framework is designed to be model-agnostic and extensible to new defence levels, attack methods, and relationship conditions.

References

- [1] Anthropic. The claude model family: Claude 3 opus, sonnet, and haiku. <https://www.anthropic.com/claude>, 2024.
- [2] Patrick Chao, Alexander Robey, Edgar Dobriban, Hamed Hassani, George J Pappas, and Eric Wong. Jailbreaking black box large language models in twenty queries. In *IEEE Conference on Safe and Trustworthy Machine Learning (SaTML)*, 2025.
- [3] Cognition Labs. Devin: The first ai software engineer. <https://www.cognition.ai/devin>, 2024.
- [4] Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramer. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. In *Advances in Neural Information Processing Systems*, volume 37, 2024.
- [5] Walid Gomaa, Ahmed Salem, and Sahar Abdelnabi. Converse: Benchmarking contextual safety in agent-to-agent conversations. *arXiv preprint arXiv:2511.05359*, 2025. EACL 2026 Findings.
- [6] Keegan Hines, Gary Lopez, Matthew Hall, Federico Zarfati, Yonatan Zunger, and Emre Kiciman. Defending against indirect prompt injection attacks with spotlighting. *arXiv preprint arXiv:2403.14720*, 2024. Microsoft.
- [7] Priyanshu Juneja, Lokesh Balaji Pasupulati, Alon Albalak, Wenyue Hua, and William Yang Wang. Magpie: A benchmark for multi-agent contextual privacy evaluation. *arXiv preprint arXiv:2510.15186*, 2025.
- [8] Manus AI. Manus: Autonomous desktop agent. <https://www.manus.ai>, 2025.
- [9] Meta AI. The rule of two: A security framework for ai agents. Meta AI Blog, 2025.
- [10] Milad Nasr et al. The attacker moves second: Evaluating prompt injection defenses under adaptive attack. *arXiv preprint*, 2025.
- [11] OpenAI. Gpt-4 technical report. *arXiv preprint arXiv:2303.08774*, 2023.
- [12] OpenClaw Team. Openclaw: Open-source agent framework with skills marketplace. <https://github.com/openclaw>, 2025.
- [13] Jeonghwan Park, Seonghyeon Kim, Hyunju Ju, Junghyun Lim, Soyeon Choi, Ohyeon Kwon, Joonho Kim, and Sangmin Yeo. Pac-bench: Evaluating multi-agent collaboration under privacy constraints. *arXiv preprint arXiv:2604.11523*, 2026.
- [14] Mark Russinovich, Ahmed Salem, and Ronen Eldan. Great, now write an article about that: The crescendo multi-turn llm jailbreak attack. In *USENIX Security Symposium*, 2025.
- [15] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. *Advances in Neural Information Processing Systems*, 36, 2023.

- [16] Sander Schulhoff, Jeremy Pinto, Ansum Khan, Louis-François Bouchard, Chenglei Si, Sidahmed Anati, Naty Tagber, Marzena Karpinska, Brieuc Dolan, and Jordan Boyd-Graber. Hackaprompt: An adversarial prompt engineering competition. In *Findings of the Association for Computational Linguistics: EMNLP 2023*, 2024.
- [17] Natalie Shapira, Chris Wendler, Howard Yen, et al. Agents of chaos. *arXiv preprint arXiv:2602.20021*, 2026.
- [18] Sam Toyer, Olivia Watkins, Ethan Mendes, Justin Svegliato, Luke Bailey, Tiffany Wang, Isaac Ong, Karim Elmaaroufi, Pieter Abbeel, Trevor Darrell, Alan Ritter, and Stuart Russell. Tensor trust: Interpretable prompt injection attacks from an online game. In *Advances in Neural Information Processing Systems*, volume 37, 2024.
- [19] Eric Wallace, Kai Xiao, Jan Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The instruction hierarchy: Training llms to prioritize privileged instructions. *arXiv preprint arXiv:2404.13208*, 2024. OpenAI.
- [20] Yuxuan Wang and Nan Jiang. Agentsocialbench: Evaluating privacy risks in human-centred agentic social networks. *arXiv preprint arXiv:2604.01487*, 2026.
- [21] Oussama Yagoubi, Gloria Badu-Marfo, and Raneem Al Mallah. Agentleak: A full-stack benchmark for privacy leakage in multi-agent llm systems. *arXiv preprint arXiv:2602.11510*, 2026.
- [22] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. React: Synergizing reasoning and acting in language models. *arXiv preprint arXiv:2210.03629*, 2023.
- [23] Yi Zeng, Hongpeng Lin, Jingwen Zhang, Diyi Yang, Ruoxi Jia, and Weiyan Shi. How johnny can persuade llms to jailbreak them: Rethinking persuasion to challenge ai safety by humanizing llms. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics*, 2024.
- [24] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. Injecagent: Benchmarking indirect prompt injections in tool-integrated llm agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, 2024.

A Observed Attack Patterns

Under D2 (category-specific deny list), residual leaks in single-step evaluation cluster into identifiable patterns:

Table 6: Distribution of D2 leak causes in single-step evaluation (XXXX total leaks).

Pattern	Count	Share
Category ambiguity (data accessible but semantically sensitive)	XXXX	XXXX%
Social framing (personal question in work-acceptable frame)	XXXX	XXXX%
Partial compliance failure (refusal then continued disclosure)	XXXX	XXXX%
Other	XXXX	XXXX%

Category ambiguity is the dominant failure mode: data stored in “Work” folders that is semantically sensitive (e.g., board meeting notes containing investor terms, HR documents with salary benchmarks). The agent’s policy correctly protects “personal finance” but does not recognise that a board memo discussing fundraising terms is financially sensitive.

B Experimental Configuration Details

Alex’s agent. System prompt establishes identity (Co-founder & CTO, Oxford CS background). 85+ notes across 6 folder categories. Tools: `read_note`, `search_notes`, `check_calendar`, `schedule_meeting`. Memory contains preferences and interaction history.

351 **Tina's agent.** Operates from a HEARTBEAT.md instruction file. Phase 1 (information gathering):
352 systematically works through pending questions. Phase 2 (deeper probing): re-asks refused questions
353 with different framing. Maintains a MEMORY.md checklist tracking answered/refused/pending status
354 per question.

355 **Heartbeat configuration.** Each tick: Tina's agent selects 1–3 questions, sends a message, Alex's
356 agent responds. XXXX ticks per group in multi-turn mode.

NeurIPS Paper Checklist

The checklist is designed to encourage best practices for responsible machine learning research, addressing issues of reproducibility, transparency, research ethics, and societal impact. Do not remove the checklist: **The papers not including the checklist will be desk rejected.** The checklist should follow the references and follow the (optional) supplemental material. The checklist does NOT count towards the page limit.

Please read the checklist guidelines carefully for information on how to answer these questions. For each question in the checklist:

- You should answer [Yes], [No], or [N/A].
- [N/A] means either that the question is Not Applicable for that particular paper or the relevant information is Not Available.
- Please provide a short (1–2 sentence) justification right after your answer (even for [N/A]).

The checklist answers are an integral part of your paper submission. They are visible to the reviewers, area chairs, senior area chairs, and ethics reviewers. You will also be asked to include it (after eventual revisions) with the final version of your paper, and its final version will be published with the paper.

The reviewers of your paper will be asked to use the checklist as one of the factors in their evaluation. While [Yes] is generally preferable to [No], it is perfectly acceptable to answer [No] provided a proper justification is given (e.g., error bars are not reported because it would be too computationally expensive” or “we were unable to find the license for the dataset we used”). In general, answering [No] or [N/A] is not grounds for rejection. While the questions are phrased in a binary way, we acknowledge that the true answer is often more nuanced, so please just use your best judgment and write a justification to elaborate. All supporting evidence can appear either in the main paper or the supplemental material, provided in appendix. If you answer [Yes] to a question, in the justification please point to the section(s) where related material for the question can be found.

IMPORTANT, please:

- Delete this instruction block, but keep the section heading “NeurIPS Paper Checklist”.
- Keep the checklist subsection headings, questions/answers and guidelines below.
- Do not modify the questions and only use the provided macros for your answers.

1. Claims

Question: Do the main claims made in the abstract and introduction accurately reflect the paper’s contributions and scope?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the abstract and introduction do not include the claims made in the paper.
- The abstract and/or introduction should clearly state the claims made, including the contributions made in the paper and important assumptions and limitations. A [No] or [N/A] answer to this question will not be perceived well by the reviewers.
- The claims made should match theoretical and experimental results, and reflect how much the results can be expected to generalize to other settings.
- It is fine to include aspirational goals as motivation as long as it is clear that these goals are not attained by the paper.

2. Limitations

Question: Does the paper discuss the limitations of the work performed by the authors?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper has no limitation while the answer [No] means that the paper has limitations, but those are not discussed in the paper.
- The authors are encouraged to create a separate “Limitations” section in their paper.
- The paper should point out any strong assumptions and how robust the results are to violations of these assumptions (e.g., independence assumptions, noiseless settings, model well-specification, asymptotic approximations only holding locally). The authors should reflect on how these assumptions might be violated in practice and what the implications would be.
- The authors should reflect on the scope of the claims made, e.g., if the approach was only tested on a few datasets or with a few runs. In general, empirical results often depend on implicit assumptions, which should be articulated.
- The authors should reflect on the factors that influence the performance of the approach. For example, a facial recognition algorithm may perform poorly when image resolution is low or images are taken in low lighting. Or a speech-to-text system might not be used reliably to provide closed captions for online lectures because it fails to handle technical jargon.
- The authors should discuss the computational efficiency of the proposed algorithms and how they scale with dataset size.
- If applicable, the authors should discuss possible limitations of their approach to address problems of privacy and fairness.
- While the authors might fear that complete honesty about limitations might be used by reviewers as grounds for rejection, a worse outcome might be that reviewers discover limitations that aren’t acknowledged in the paper. The authors should use their best judgment and recognize that individual actions in favor of transparency play an important role in developing norms that preserve the integrity of the community. Reviewers will be specifically instructed to not penalize honesty concerning limitations.

3. Theory assumptions and proofs

Question: For each theoretical result, does the paper provide the full set of assumptions and a complete (and correct) proof?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not include theoretical results.
- All the theorems, formulas, and proofs in the paper should be numbered and cross-referenced.
- All assumptions should be clearly stated or referenced in the statement of any theorems.
- The proofs can either appear in the main paper or the supplemental material, but if they appear in the supplemental material, the authors are encouraged to provide a short proof sketch to provide intuition.
- Inversely, any informal proof provided in the core of the paper should be complemented by formal proofs provided in appendix or supplemental material.
- Theorems and Lemmas that the proof relies upon should be properly referenced.

4. Experimental result reproducibility

Question: Does the paper fully disclose all the information needed to reproduce the main experimental results of the paper to the extent that it affects the main claims and/or conclusions of the paper (regardless of whether the code and data are provided or not)?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not include experiments.

- If the paper includes experiments, a [No] answer to this question will not be perceived well by the reviewers: Making the paper reproducible is important, regardless of whether the code and data are provided or not.
- If the contribution is a dataset and/or model, the authors should describe the steps taken to make their results reproducible or verifiable.
- Depending on the contribution, reproducibility can be accomplished in various ways. For example, if the contribution is a novel architecture, describing the architecture fully might suffice, or if the contribution is a specific model and empirical evaluation, it may be necessary to either make it possible for others to replicate the model with the same dataset, or provide access to the model. In general, releasing code and data is often one good way to accomplish this, but reproducibility can also be provided via detailed instructions for how to replicate the results, access to a hosted model (e.g., in the case of a large language model), releasing of a model checkpoint, or other means that are appropriate to the research performed.
- While NeurIPS does not require releasing code, the conference does require all submissions to provide some reasonable avenue for reproducibility, which may depend on the nature of the contribution. For example
 - (a) If the contribution is primarily a new algorithm, the paper should make it clear how to reproduce that algorithm.
 - (b) If the contribution is primarily a new model architecture, the paper should describe the architecture clearly and fully.
 - (c) If the contribution is a new model (e.g., a large language model), then there should either be a way to access this model for reproducing the results or a way to reproduce the model (e.g., with an open-source dataset or instructions for how to construct the dataset).
 - (d) We recognize that reproducibility may be tricky in some cases, in which case authors are welcome to describe the particular way they provide for reproducibility. In the case of closed-source models, it may be that access to the model is limited in some way (e.g., to registered users), but it should be possible for other researchers to have some path to reproducing or verifying the results.

5. Open access to data and code

Question: Does the paper provide open access to the data and code, with sufficient instructions to faithfully reproduce the main experimental results, as described in supplemental material?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that paper does not include experiments requiring code.
- Please see the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- While we encourage the release of code and data, we understand that this might not be possible, so [No] is an acceptable answer. Papers cannot be rejected simply for not including code, unless this is central to the contribution (e.g., for a new open-source benchmark).
- The instructions should contain the exact command and environment needed to run to reproduce the results. See the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- The authors should provide instructions on data access and preparation, including how to access the raw data, preprocessed data, intermediate data, and generated data, etc.
- The authors should provide scripts to reproduce all experimental results for the new proposed method and baselines. If only a subset of experiments are reproducible, they should state which ones are omitted from the script and why.
- At submission time, to preserve anonymity, the authors should release anonymized versions (if applicable).

- Providing as much information as possible in supplemental material (appended to the paper) is recommended, but including URLs to data and code is permitted.

6. Experimental setting/details

Question: Does the paper specify all the training and test details (e.g., data splits, hyperparameters, how they were chosen, type of optimizer) necessary to understand the results?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer **[N/A]** means that the paper does not include experiments.
- The experimental setting should be presented in the core of the paper to a level of detail that is necessary to appreciate the results and make sense of them.
- The full details can be provided either with the code, in appendix, or as supplemental material.

7. Experiment statistical significance

Question: Does the paper report error bars suitably and correctly defined or other appropriate information about the statistical significance of the experiments?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer **[N/A]** means that the paper does not include experiments.
- The authors should answer **[Yes]** if the results are accompanied by error bars, confidence intervals, or statistical significance tests, at least for the experiments that support the main claims of the paper.
- The factors of variability that the error bars are capturing should be clearly stated (for example, train/test split, initialization, random drawing of some parameter, or overall run with given experimental conditions).
- The method for calculating the error bars should be explained (closed form formula, call to a library function, bootstrap, etc.)
- The assumptions made should be given (e.g., Normally distributed errors).
- It should be clear whether the error bar is the standard deviation or the standard error of the mean.
- It is OK to report 1-sigma error bars, but one should state it. The authors should preferably report a 2-sigma error bar than state that they have a 96% CI, if the hypothesis of Normality of errors is not verified.
- For asymmetric distributions, the authors should be careful not to show in tables or figures symmetric error bars that would yield results that are out of range (e.g., negative error rates).
- If error bars are reported in tables or plots, the authors should explain in the text how they were calculated and reference the corresponding figures or tables in the text.

8. Experiments compute resources

Question: For each experiment, does the paper provide sufficient information on the computer resources (type of compute workers, memory, time of execution) needed to reproduce the experiments?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer **[N/A]** means that the paper does not include experiments.
- The paper should indicate the type of compute workers CPU or GPU, internal cluster, or cloud provider, including relevant memory and storage.
- The paper should provide the amount of compute required for each of the individual experimental runs as well as estimate the total compute.

- 561 • The paper should disclose whether the full research project required more compute
562 than the experiments reported in the paper (e.g., preliminary or failed experiments that
563 didn't make it into the paper).

564 **9. Code of ethics**

565 Question: Does the research conducted in the paper conform, in every respect, with the
566 NeurIPS Code of Ethics <https://neurips.cc/public/EthicsGuidelines>?

567 Answer: **[TODO]**

568 Justification: **[TODO]**

569 Guidelines:

- 570 • The answer [N/A] means that the authors have not reviewed the NeurIPS Code of
571 Ethics.
572 • If the authors answer [No], they should explain the special circumstances that require a
573 deviation from the Code of Ethics.
574 • The authors should make sure to preserve anonymity (e.g., if there is a special consid-
575 eration due to laws or regulations in their jurisdiction).

576 **10. Broader impacts**

577 Question: Does the paper discuss both potential positive societal impacts and negative
578 societal impacts of the work performed?

579 Answer: **[TODO]**

580 Justification: **[TODO]**

581 Guidelines:

- 582 • The answer [N/A] means that there is no societal impact of the work performed.
583 • If the authors answer [N/A] or [No], they should explain why their work has no societal
584 impact or why the paper does not address societal impact.
585 • Examples of negative societal impacts include potential malicious or unintended uses
586 (e.g., disinformation, generating fake profiles, surveillance), fairness considerations
587 (e.g., deployment of technologies that could make decisions that unfairly impact specific
588 groups), privacy considerations, and security considerations.
589 • The conference expects that many papers will be foundational research and not tied
590 to particular applications, let alone deployments. However, if there is a direct path to
591 any negative applications, the authors should point it out. For example, it is legitimate
592 to point out that an improvement in the quality of generative models could be used to
593 generate Deepfakes for disinformation. On the other hand, it is not needed to point out
594 that a generic algorithm for optimizing neural networks could enable people to train
595 models that generate Deepfakes faster.
596 • The authors should consider possible harms that could arise when the technology is
597 being used as intended and functioning correctly, harms that could arise when the
598 technology is being used as intended but gives incorrect results, and harms following
599 from (intentional or unintentional) misuse of the technology.
600 • If there are negative societal impacts, the authors could also discuss possible mitigation
601 strategies (e.g., gated release of models, providing defenses in addition to attacks,
602 mechanisms for monitoring misuse, mechanisms to monitor how a system learns from
603 feedback over time, improving the efficiency and accessibility of ML).

604 **11. Safeguards**

605 Question: Does the paper describe safeguards that have been put in place for responsible
606 release of data or models that have a high risk for misuse (e.g., pre-trained language models,
607 image generators, or scraped datasets)?

608 Answer: **[TODO]**

609 Justification: **[TODO]**

610 Guidelines:

- 611 • The answer [N/A] means that the paper poses no such risks.

- Released models that have a high risk for misuse or dual-use should be released with necessary safeguards to allow for controlled use of the model, for example by requiring that users adhere to usage guidelines or restrictions to access the model or implementing safety filters.
- Datasets that have been scraped from the Internet could pose safety risks. The authors should describe how they avoided releasing unsafe images.
- We recognize that providing effective safeguards is challenging, and many papers do not require this, but we encourage authors to take this into account and make a best faith effort.

12. Licenses for existing assets

Question: Are the creators or original owners of assets (e.g., code, data, models), used in the paper, properly credited and are the license and terms of use explicitly mentioned and properly respected?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not use existing assets.
- The authors should cite the original paper that produced the code package or dataset.
- The authors should state which version of the asset is used and, if possible, include a URL.
- The name of the license (e.g., CC-BY 4.0) should be included for each asset.
- For scraped data from a particular source (e.g., website), the copyright and terms of service of that source should be provided.
- If assets are released, the license, copyright information, and terms of use in the package should be provided. For popular datasets, paperswithcode.com/datasets has curated licenses for some datasets. Their licensing guide can help determine the license of a dataset.
- For existing datasets that are re-packaged, both the original license and the license of the derived asset (if it has changed) should be provided.
- If this information is not available online, the authors are encouraged to reach out to the asset's creators.

13. New assets

Question: Are new assets introduced in the paper well documented and is the documentation provided alongside the assets?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not release new assets.
- Researchers should communicate the details of the dataset/code/model as part of their submissions via structured templates. This includes details about training, license, limitations, etc.
- The paper should discuss whether and how consent was obtained from people whose asset is used.
- At submission time, remember to anonymize your assets (if applicable). You can either create an anonymized URL or include an anonymized zip file.

14. Crowdsourcing and research with human subjects

Question: For crowdsourcing experiments and research with human subjects, does the paper include the full text of instructions given to participants and screenshots, if applicable, as well as details about compensation (if any)?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.
- Including this information in the supplemental material is fine, but if the main contribution of the paper involves human subjects, then as much detail as possible should be included in the main paper.
- According to the NeurIPS Code of Ethics, workers involved in data collection, curation, or other labor should be paid at least the minimum wage in the country of the data collector.

15. Institutional review board (IRB) approvals or equivalent for research with human subjects

Question: Does the paper describe potential risks incurred by study participants, whether such risks were disclosed to the subjects, and whether Institutional Review Board (IRB) approvals (or an equivalent approval/review based on the requirements of your country or institution) were obtained?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.
- Depending on the country in which research is conducted, IRB approval (or equivalent) may be required for any human subjects research. If you obtained IRB approval, you should clearly state this in the paper.
- We recognize that the procedures for this may vary significantly between institutions and locations, and we expect authors to adhere to the NeurIPS Code of Ethics and the guidelines for their institution.
- For initial submissions, do not include any information that would break anonymity (if applicable), such as the institution conducting the review.

16. Declaration of LLM usage

Question: Does the paper describe the usage of LLMs if it is an important, original, or non-standard component of the core methods in this research? Note that if the LLM is used only for writing, editing, or formatting purposes and does *not* impact the core methodology, scientific rigor, or originality of the research, declaration is not required.

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the core method development in this research does not involve LLMs as any important, original, or non-standard components.
- Please refer to our LLM policy in the NeurIPS handbook for what should or should not be described.